Vulnerability Assessment and Penetration Testing (CYL65) Lab

1a. Imagine you are working as a cybersecurity analyst for a financial institution, you have been assigned the critical task of conducting a Nessus vulnerability analysis on a critical host system (windows, Linux) in the local network hosting sensitive customer data. Detail your step-step approach, including pre-scan preparations, specific **Nessus** configurations for maximum efficacy in an environment, scan the targets, prioritize and analyse the results and generate reports.

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.

Nessus, developed by Tenable Inc, is a widely-used open-source vulnerability scanner. Nessus provides a range of services, including vulnerability assessments, network scans, web scans, asset discovery, and more, to aid security professionals, penetration testers, and other cybersecurity enthusiasts in proactively identifying and mitigating vulnerabilities in their networks.

Nessus tool for vulnerability scanner

https://www.tenable.com/products/nessus/nessus-essentials

Installing Nessus on kali Linux

1. Download the Nessus package for Debian on the Nessus website and make sure you set the Platform to Linux-Debian-amd64.
2. When it's finished downloading, open your Linux terminal and navigate to the location you downloaded the Nessus file to.
3. Install Nessus using this command:

4. Start the Nessus service with this command:

5. On your browser, go to .
   It would show a warning page.
6. Click on Advanced. Then, click on Accept Risk and Continue.
7. Choose the Nessus Product you prefer. If you want the free version of Nessus, click on Nessus Essentials.
8. Enter your name and email address to receive an activation code by email. Paste the activation code into the space provided and choose a username and password.

9. Allow Nessus to download the necessary plugins.

10. Once the plugin downloads have completed, you can start using the Nessus service.

Passwd Change

After installing the required plugins, navigate to the module. Enter the IP address of the Metasploitable2 target for scanning. You have the flexibility to schedule scans for specific times or days, or perform OnDemand scanning.

Select from various scan options such as host discovery, basic scan, or advanced scan. Once the scanning process is finished, proceed to analyse the vulnerabilities categorized by their severity levels such as medium, high, or critical, along with their respective CVSS (Common Vulnerability Scoring System) scores.

Check for available remediation's for each vulnerability and generate a comprehensive PDF report summarizing the scan results, including identified vulnerabilities, their severity, CVSS scores, and recommended actions for mitigation.

Note: After installing Nessus on Kali Linux, ensure that the nessusd service is running every time you log in. This ensures continuous availability of Nessus functionality

in the browser.

1b. As part of a penetration testing engagement for a client, you're tasked with evaluating the security of their internal network. You suspect that sensitive data might be leaking from one of their development servers due to a potential misconfiguration or a compromised machine within their network. To investigate further, you plan to intercept network traffic using **Wireshark** to identify any unauthorized data transfers.

Wireshark is a widely used, open source network analyzer that can capture and display real-time details of network traffic. It is particularly useful for troubleshooting network issues, analyzing network protocols and ensuring network security.
Networks must be monitored to ensure smooth operations and security. Popular with academic institutions, government agencies, corporations and nonprofits, Wireshark is one such tool that can offer an in-depth view into network activities, diagnose network performance issues or identify potential security threats.

Wireshark -Snipping

Intercept target machine traffic (Metaspoiltable2 VM) with Wireshark

- Ensure both the Kali Linux and Metasploitable2 virtual machines are up and running.
- Open Kali Linux and navigate to Applications -> Snipping & Spoofing -> Wireshark.
- Select the interface () to capture network traffic.
  - Access the browser on Kali Linux and enter the IP address of the Metasploitable2 VM (e.g., 192.168.62.129) to open the Mutillidae website.
- Navigate to Mutillidae page and proceed to the login page.
- Enter random credentials (e.g., username: admin, password: 12345) and attempt to log in, resulting in a login failure message.

- Switch to Wireshark, where traffic interception has begun.
- In the filter bar, type "http" and select the http with post stream contains login.php page.
- Right-click on HTTP traffic, choose "Follow," then "HTTP stream" to open a new window.
- The new window displays intercepted traffic containing the username and password entered on the DVWA login page, showcasing successful traffic interception using Wireshark.

2a. As a member of Blue team experts in Monitoring and Technical Support of a medium sized company, you have been asked to assess the security posture of the internal network. Use **Nmap** for network discovery, Port scanning, Service version detection and vulnerability detection. Then Document your findings, including the identified vulnerabilities, their severity levels.

Nmap ("Network Mapper") is a free and open source utility for network discovery and security auditing. Many systems and network administrators also find it useful for tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics. It was designed to rapidly scan large networks, but works fine against single hosts. Nmap runs on all major computer operating systems, and official binary packages are available for Linux, Windows, and Mac OS X.

Nmap Scanning:

- Open Kali Linux and the Metasploitable2 virtual machine.
- Obtain the IP address of the target machine (Metasploitable2 VM).
- Open the terminal in Kali Linux.
- Perform scanning using the following commands with nmap:

1.
2.
3.
4.
5.
6.
7.
8.
9.

10.
11.

12.

OS Detection:

-
-
-

Service Detection:-

-
-

Advanced Scan:-

-
-
-
-
-

Custom scan:-

nmap -sS --scanflags SYNFIN -T4 www.google.com nmap -sO

192.168.62.129(IP protocol scan)

Send Ethernet packets:

Send IP packets

2b. Imagine you are a member of Red Team in a company, you have been assigned a penetration testing task to assess the security of a corporate network using Kali Linux and the Metasploit framework. Outline a step-by-step process for utilizing Metasploit to identify and exploit vulnerabilities within the network.

Ensure both the Kali Linux and Metasploitable2 virtual machines are up and running.

Open Kali Linux terminal, type following cmds

—"Use this if metaspoilt-framework is more than two weeks old. Run msfupdate to get latest

framework”

➢

➢

➢

➢

➢

➢ It will open the shell of target IP (metaspoiltable vm)

➢ Create a file say with some contents, copy the file to another new file.

➢ Now goto Metaspoiltable VM 2 and check the same file contents.

➢ Even the sensitive details such contents of file also can be accessed.

Database Commands for Connection & Status

These commands are used within the prompt to interact with the connected database.

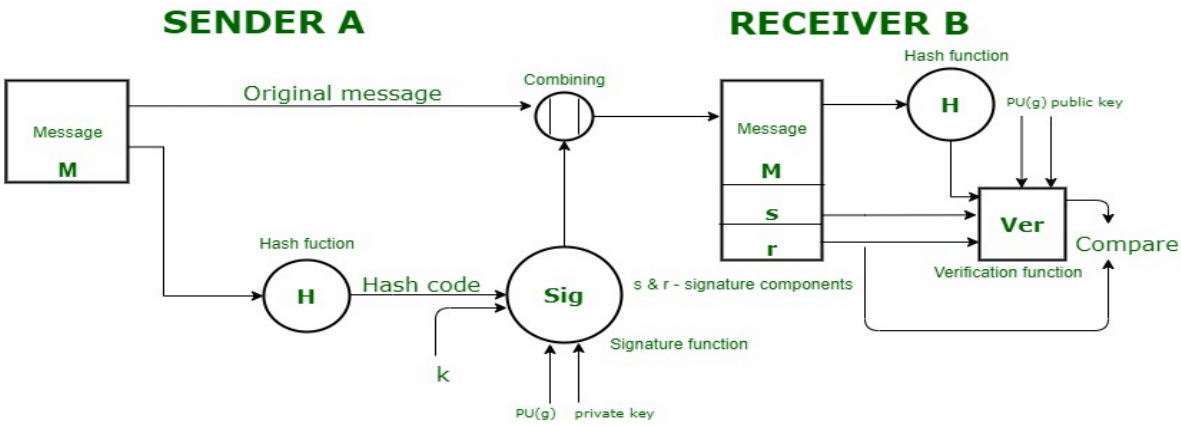
- : Checks the connection status to the database.
- : Manually connects to a specific database.
- Disconnects from the current database connection.

Data Collection & Management

- Runs an Nmap scan and automatically saves the results (hosts, services) to the database.
- Imports scan results from an external file (supports Nmap XML, Nessus, etc.) into the database.
-

3. Imagine a legal firm handling contracts for clients remotely. Let’s say a client, Mr. John, needs to sign a contract for a property purchase. how could Cryptool be applied to digitally sign a contract document, authenticate its validity, and ensure the secure storage of both the digital signature and the original document? Demonstrate the use of digital signatures using cryptool by performing following things:
   - Creation of signature
   - Storing the signature
   - Verifying the signature

A **digital signature** is a secure, cryptographic, electronic stamp of authentication for digital documents, emails, or transactions. It guarantees the document’s integrity (has not been tampered with) and verifies the signer's identity using a certificate-based Public Key Infrastructure (PKI).



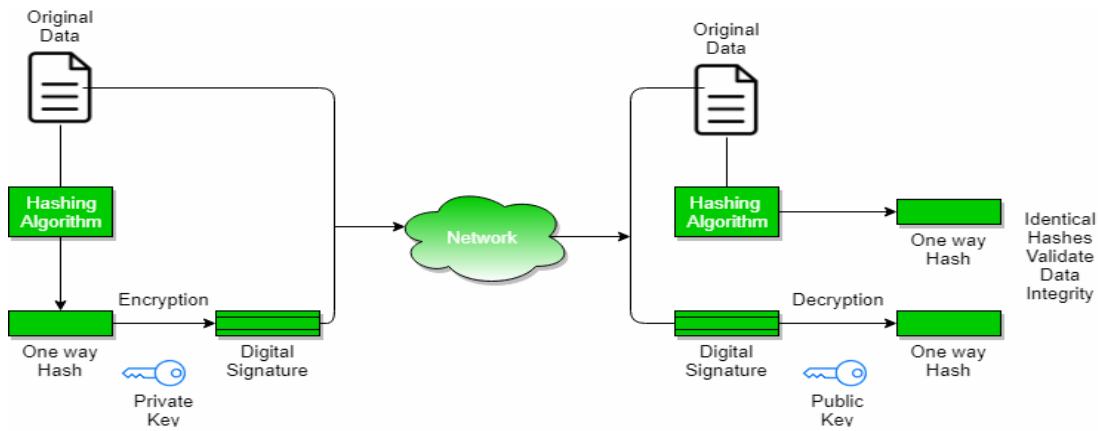
Demo: -

- Download Cryptool2 on windows machine.

https://www.cryptool.org/en/ct2/downloads Download .exe stable version(165.65MB)

- Install Cryptool
- Perform Encryption and Decryption using RSA algorithm and Create hashes for the file using SHA algorithm

Encryption & Decryption



Note: Add screenshots of actual execution for atleast 2 encryption and 2 hashes in record